

clients, and should be uninstalled. These programs run services that are prime targets for malicious code, which usually hijacks the service to wreak all sorts of havoc on your network. And, of course, there's the lack of productivity that IM clients encourage so much.

Bottom line: if you don't need it for work, it shouldn't be installed.

Auditing The Network

Here's where things get tricky. Network security isn't something you can learn very easily, so you might have to spend a lot of time reading up on the Internet, or solicit the help of an expert. But first, let's get the easy stuff done with...

If you use the Squid proxy server to control access to the Internet (and you should), you can start with blocking social networking sites, among others that could affect productivity. You can also block most popular banner advertisement servers and replace the ads with a message.

Now comes the tricky part—scanning the computers on your network for open ports. Network Ports let PCs—more specifically, services running on PCs—access the network and the Internet, and also act as ways into your PC. Usually, most ports on your PC are closed, and don't accept incoming connections. That doesn't really mean that open ports are an invitation to hackers—they just accept incoming requests for data. Running a port scan on a PC (using a tool called nmap, which has Windows-based GUIs too) gives you an idea of which services are using which ports. You can then go about disabling services that could potentially be exploited—like those pesky IM services. If you've been compromised before, a port scan is essential, but if you've had no security problems thus far, you could just install firewall software on each PC and be done with it.

Other Audits

You also need to check up on your backup solution—the frequency of backups, and so on, and perhaps build some redundancy by storing some critical data on an online backup solution—just in case.

Your e-mail server needs to have proper anti-spam and anti-phishing measures built into it—just one successful phishing attack can become a slap in the face of all you've done so far.

Failing An Audit

If you're done with an audit and have passed with flying colours, chances are you didn't do it right. Around 99 per cent of companies who undergo a security audit fail, but it's a part of life. What you need to do now is start addressing

```
# nmap -A -T4 scanme.nmap.org -d0ze

Starting Nmap 4.01 ( http://www.insecure.org/nmap/ ) at 2006-03-20 15:53 PST
Interesting ports on scanme.nmap.org (206.217.153.62):
(The 1667 ports scanned but not shown below are in state: filtered)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 3.9p1 (protocol 1.99)
25/tcp    open  smtp      Postfix smtpd
53/tcp    open  domain    ISC Bind 9.2.1
70/tcp    closed gopher
80/tcp    open  http      Apache httpd 2.0.52 ((Fedora))
113/tcp   closed auth
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.0 - 2.6.11
Uptime 26.177 days (since Wed Feb 22 11:39:16 2006)

Interesting ports on d0ze.internal (192.168.12.3):
(The 1664 ports scanned but not shown below are in state: closed)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp       Serv-U ftpd 4.0
25/tcp    open  smtp      IMail NT-ESMTP 7.15 2015-2
80/tcp    open  http      Microsoft IIS webserver 5.0
110/tcp   open  pop3      IMail pop3d 7.15 931-1
135/tcp   open  mstask    Microsoft mstask (task server - c:\winnt\system32\
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1025/tcp  open  msrpc     Microsoft Windows RPC
5800/tcp  open  vnc-http  UltraVNC (Resolution 1024x800; VNC TCP port: 5900)
5900/tcp  open  vnc-http  UltraVNC (Resolution 1024x800; VNC TCP port: 5900)
Device type: general purpose
Running: Microsoft Windows NT/2K/XP
OS details: Microsoft Windows 2000 Professional
Service Info: OS: Windows

Nmap finished: 2 IP addresses (2 hosts up) scanned in 42.291 seconds
flag/home/tyodor/nmap-misc/Screenshots/042006#
```

nmap is the tool of choice when it comes to scanning PCs on your network or open ports

issues immediately. Based on your audit, you'll be able to figure out the probability of a scenario more accurately, so you need to make your risk assessment calculations with new values. Once that's done, you've got yourself a prioritised list of the problems you should be attacking.

With the laptop problem we saw before, there's plenty of potential for damage if it were to get stolen or misplaced. To mitigate this risk, encrypt the laptop's hard disks. This way, even if the laptop does fall into the wrong hands, it's virtually useless in them, and more importantly, none of your data can be read.

The Aftermath

Once you're finished with a security audit, make sure you keep the results handy for your next audit. The results of the audit will give you enough food for thought, and will help you correct flaws in your security policy. Share an overview of the audit with your team, so they too can know what they can do to reduce your risks. If you found a lot of critical flaws in this audit, make sure you schedule a new audit as soon as you've addressed these flaws. If this is your first audit, schedule another one very soon, and ensure that you're auditing your security at least thrice a year.

Finally—and we've mentioned this many times in these pages—there is no substitute for an informed and educated team. Therefore, security shouldn't be just your concern—it should be everyone's. ■

nimish.chandiramani@thinkdigit.com